

Visão da Norma de Segurança da Informação ISO 27001

Objetivo da Aula

Conhecer os princípios e a estrutura da norma de segurança da informação ISO 27001, norma amplamente utilizada para proteger os ativos da informação de uma organização.

Apresentação

A norma de segurança da informação ISO 27001 é um padrão internacional que estabelece os requisitos para um sistema de gestão de segurança da informação eficaz. Ela fornece uma estrutura abrangente para proteger os ativos da informação de uma organização, garantindo a confidencialidade, integridade e disponibilidade dos dados.

A ISO 27001 segue uma abordagem baseada em riscos para a segurança da informação, o que significa que as organizações devem identificar e avaliar os riscos de segurança da informação que enfrentam e, em seguida, implementar controles adequados para mitigar estes riscos.

1. Para que Serve a ISO 27001?

Assim como outras normas ISO, a ISO 27001 é um padrão internacional desenvolvido pela *International Organization for Standardization* (ISO, Organização Internacional pela Padronização), sediada em Genebra, Suíça.

Essas normas são criadas para estabelecer diretrizes, requisitos e especificações técnicas, que visam garantir a qualidade, segurança, eficiência e interoperabilidade de produtos, serviços e sistemas em várias indústrias e áreas de atuação.

Uma destas áreas de atuação é a segurança da informação, que pode ser exemplificada pela ISO 27001. Criada pelo Governo Britânico, então com o nome de BS7799, a 27001 vem sendo melhorada e mantida atualizada desde a sua concepção em 1992. Colocada em uso

por milhares de profissionais de diversas áreas pelo mundo inteiro, a ISO 27001 entrega um padrão estável e maduro, capaz de evoluir e se adaptar ao longo dos tempos.

Esta norma busca trazer às organizações que a implementarem um complexo conjunto de requisitos, processos e controles, que possuem o objetivo de mitigar e gerir os riscos de TIC dentro da organização. As organizações que decidirem adotar esta norma podem buscar certificados, que garantem a lisura de todo o processo padronizado e todos os benefícios que ele traz para a empresa.

Existem casos em que o certificado relativo a esta norma é exigido por outras organizações ou governos parceiros. A certificação garante o cumprimento dos princípios estabelecidos pela norma, para providenciar aos clientes e parceiros um elevado nível de confiança na segurança. A conformidade com a ISO 27001 pode ser incentivada ou exigida por regulamentos, contratos ou parceiros. Por exemplo:

- **Requisitos contratuais:**

- Alguns contratos com clientes ou parceiros de negócios podem exigir que a organização seja certificada de acordo com a ISO 27001 como parte dos requisitos para prestação de serviços ou fornecimento de produtos.

- **Regulamentações setoriais:**

- Em alguns setores, como serviços financeiros ou saúde, regulamentações específicas podem exigir que as organizações implementem controles de segurança da informação, e a ISO 27001 pode ser usada como um guia para atender a esses requisitos.

- **Exigências de Segurança da Informação:**

- Países ou regiões com regulamentos específicos podem exigir ou incentivar que certas normas sejam utilizadas. Tal como fazem a RGPD europeia e a sua versão brasileira, a LGPD;
- A ISO 27001 pode não ser obrigatória, mas é uma ferramenta muito valiosa para que seja possível atender os requisitos impostos por estas leis/regulamentos.

- **Vantagens competitivas no mercado:**

- Em muitos setores, a conformidade com a ISO 27001 é vista como uma demonstração de compromisso com as melhores práticas de segurança da informação, o que pode melhorar a confiança dos clientes e parceiros de negócios;
- Se a sua organização obtiver o certificado e os concorrentes não, a sua organização possui uma vantagem competitiva sobre as outras;

- Também é possível argumentar que a gerência de riscos evita perdas financeiras, portanto, a implementação de gerência de riscos pode ser vista como uma forma de reduzir custos a longo prazo.

Em resumo, embora a ISO 27001 não seja obrigatória por si só, sua implementação e certificação podem ser exigidas ou incentivadas em determinadas situações, dependendo das necessidades e regulamentações específicas de uma organização ou setor. As organizações que buscam a conformidade com a ISO 27001 devem fazê-la voluntariamente, com base em suas próprias circunstâncias e objetivos.

1.1. ISMS de acordo com a ISO 27001

Information Security Management System (Sistema de Gerenciamento de Segurança da Informação, em tradução livre) é um conjunto de processos, políticas, procedimentos e controles organizacionais que visa proteger a confidencialidade, integridade e disponibilidade da informação de uma organização. Ou seja, é o sistema que possibilita gerenciar e controlar os riscos.

De certa forma, a produção de uma ISMS é o produto da ISO 27001. De forma abrangente, os objetivos desta ISMS são:

- Identificar as partes interessadas e suas expectativas em relação à segurança da informação da empresa;
- Identificar que riscos existem para a informação;
- Definir controles e outros métodos de mitigação para atender as expectativas identificadas e lidar com os riscos;
- Estabelecer objetivos claros sobre o que precisa ser alcançado com a segurança da informação;
- Implementar todos os controles e outros métodos de tratamento de risco;
- Medir continuamente se os controles implementados estão funcionando conforme o esperado;
- Praticar melhorias contínuas para tornar todo o sistema mais eficiente.

Deve-se registrar estes objetivos em formas de políticas, procedimentos e outros tipos de documentos. Segundo a ISMS, implementada via ISO 27001, o tipo de controle

a ser utilizado na segurança de informação deve ser decidido com base nos resultados de avaliações de riscos e nos requisitos das partes interessadas. Ou seja, cada risco a ser tratado utiliza uma combinação diferente de controles e recursos.

2. Princípios Básicos

A ISO 27001 é orientada por uma série de princípios fundamentais, que são essenciais para o sucesso do Sistema de Gestão de Segurança da Informação. Estes princípios são: Abordagem Baseada em Riscos; Compromisso da Alta Direção; Melhoria Contínua; Atendimento a Requisitos Legais e Reguladores; Envolvimento das Partes Interessadas; Adaptação ao Contexto da Organização; e Aprendizado Organizacional.

A abordagem baseada em riscos é um dos princípios mais cruciais da norma ISO 27001. Esta abordagem reconhece que todas as organizações enfrentam riscos de segurança da informação, e esses riscos podem variar em gravidade, prioridade e impacto. A norma incentiva as organizações a identificar, avaliar e priorizar esses riscos, levando em consideração ameaças, vulnerabilidades e impactos potenciais. Com base nessa análise de riscos, as organizações podem tomar decisões informadas sobre quais controles de segurança implementar e como alocar recursos eficazmente.

Já o compromisso da alta direção é um requerimento comum em normas de segurança. A liderança da organização, incluindo alta direção, deve demonstrar comprometimento com a segurança da informação. Isto envolve estabelecer uma cultura de segurança, alocar recursos adequados e garantir que a segurança da informação seja considerada uma prioridade estratégica. O comprometimento da alta direção é essencial para garantir que a organização esteja alinhada com os objetivos de segurança da informação e que os recursos necessários sejam disponibilizados para implementar e manter o ISMS.

A este ponto, já sabemos que as ameaças evoluem continuamente e, portanto, as medidas de proteção também devem evoluir de acordo para garantir a integridade, disponibilidade e confidencialidade dos dados. Por isso, a ISO 27001 promove a ideia de melhoria contínua, no que diz respeito à segurança da informação. Isto significa que as organizações devem revisar periodicamente seu ISMS, avaliar seu desempenho, identificar áreas de melhoria e implementar ações corretivas e preventivas. A melhoria contínua garante que o ISMS evolua de acordo com as mudanças nas ameaças, tecnologias e necessidades da organização, mantendo-o eficaz e relevante ao longo do tempo.

Requisitos legais e regulatórios são grandes motivadores para a criação destas normas internacionais, capazes de padronizar organizações distintas. A conformidade com as leis e regulamentos relacionados à segurança da informação é um dos princípios fundamentais da 27001. As organizações devem garantir que o seu ISMS esteja em conformidade com todas as exigências legais e regulatórias aplicáveis. Isso inclui a conformidade com leis de proteção de dados, regulamentações específicas da indústria e outras obrigações legais relacionadas à segurança da informação.

A ISO 27001 enfatiza a importância de identificar e envolver todas as partes interessadas relevantes no processo de segurança da informação. Isto inclui funcionários, clientes, parceiros de negócios e outras partes, que têm interesse nas operações da organização. O envolvimento das partes interessadas ajuda a garantir que as necessidades e expectativas delas sejam consideradas na definição dos objetivos de segurança da informação e na implementação dos controles.

Como uma ferramenta de padronização, a ISO 27001 prevê que será implementada em diversas organizações diferentes e então reconhece que cada organização é única em sua estrutura, tamanho, objetivos e ambiente operacional. Portanto, o ISMS deve ser adaptado ao contexto específico da organização. Isso significa que as abordagens e os controles de segurança podem variar de acordo com as necessidades e características da organização, garantindo que o ISMS seja eficaz e apropriado para sua situação específica.

A organização deve aprender com incidentes de segurança passados e outras experiências relacionadas à segurança da informação. Isto inclui análise de incidentes de segurança, identificação de causas raiz e implementação de medidas para evitar que esses incidentes se repitam. O aprendizado organizacional contribui para um ISMS mais robusto e eficaz ao longo do tempo.

Estes princípios fundamentais orientam as organizações na implementação bem-sucedida da ISO 27001, ajudando a criar um ambiente de segurança da informação sólida, adaptável, e focada em riscos. Eles refletem melhores práticas em segurança da informação e promovem uma abordagem proativa para proteger os ativos de informação contra ameaças e riscos.

Você sabia? A implementação da ISO 27001 não se limita apenas a grandes empresas ou organizações de tecnologia. Ela pode ser implementada com sucesso em empresas de todos os tamanhos e em diversas indústrias. Isto significa que é possível para uma pequena empresa se destacar competitivamente no mercado ao aderir a esta norma internacional.

3. Estrutura ISO 27001

A norma ISO 27001 é estruturada para orientar as organizações na criação de um sistema de gestão de segurança da informação (ISMS) eficaz. Sua estrutura é projetada para ser abrangente, flexível e adaptável às necessidades de diferentes organizações, independentemente do tamanho ou do setor em que atuam.

Para começar a criar a estrutura da ISO 27001, é necessário, primeiro, definir o escopo, que delimita quais partes da organização e quais ativos de informação serão cobertos pela norma. Isto permite que as organizações adaptem o ISM de acordo com sua estrutura interna e seus requisitos específicos de segurança. Em seguida, a norma estabelece uma base sólida, com termos e definições claros, garantindo que todos os envolvidos tenham um entendimento comum de dois conceitos-chave relacionados à segurança da informação.

Também se destaca, dentro da norma, a importância do contexto da organização, incentivando as empresas a entenderem sua estrutura, cultura, ambiente de negócios e partes interessadas relevantes. Esta compreensão é fundamental para a definição de objetivos de segurança da informação alinhados com os objetivos estratégicos da organização.

Outro ponto crucial é o compromisso de alta direção. A norma enfatiza que a liderança da organização deve estar comprometida com a segurança da informação, garantindo que recursos adequados sejam alocados e que a cultura de segurança seja promovida em toda a organização.

O planejamento desempenha um papel central na estrutura da ISO 27001, com ênfase na identificação de riscos de segurança da informação e na implementação de controles apropriados para mitigá-los. A norma também destaca a necessidade de apoio, garantindo que recursos, conscientização e competência sejam fornecidos para manter o ISMS eficaz.

Durante a operação do ISMS, a norma incentiva a implementação das ações planejadas, a medição do desempenho e a avaliação contínua. A avaliação de desempenho inclui auditorias internas e análise crítica pela direção, garantindo que o ISMS esteja funcionando conforme o esperado.

Repare novamente como a estrutura não é tão detalhada assim, mesmo neste rápido resumo da norma. Então, você pode se perguntar, “por que eu precisaria de um padrão que não me diz nada concreto?” Bem, a função da ISO 27001 não é lhe prescrever o que você deve ou não fazer, mas mostrar caminhos e soluções, por meio de um **framework** adaptável para todos os tipos de risco e ameaças, que podem, e devem, ser adaptados para a sua organização.

Considere a ação de efetuar um **backup**. Uma empresa pequena, com poucos clientes ou produtos, pode precisar de um ritmo de **backup** muito inferior do que uma empresa como a Gran Faculdade, que lida com milhares de alunos, professores, provas, vídeos e materiais diariamente. A frequência de **backups** elevada é muito mais importante para a Gran Faculdades do que para esta empresa imaginária, pois o potencial de impacto é muito maior. Dessa forma, a ISO 27001 deve ser utilizada, considerando a sua organização e a sua área de atividade.

4. Certificado ISO 27001

A certificação de qualquer organização é, sem dúvidas, uma vantagem no mercado, que permite à empresa disputar com outras grandes organizações. Porém, é claro que esta certificação não vem de graça; requer compromisso e recursos como investimento em sua preparação.

Figura 1: Certificação ISO 27001



Fonte: Elaboração própria (2024).

É difícil, talvez até impossível, fazer o passo a passo perfeito do caminho a ser percorrido para que sua organização consiga o certificado ISO 27001. Entretanto, o objetivo do processo mapeado na figura 1 é dar uma luz quanto a que passos devem ser tomados para que seja possível a sua organização obter o certificado.

Os tempos de cada etapa variam drasticamente de acordo com o escopo, objetivos e táticas utilizadas pela organização que busca se certificar. Considere esta lista como um **check-up** básico, uma lista de afazeres simples, porém cruciais para o sucesso na certificação de sua organização.

O primeiro passo sempre deve ser trazer a alta diretoria e as pessoas interessadas relevantes para o seu lado. Apenas com o suporte da alta gestão de sua empresa é possível realizar os demais passos e alterações necessárias dentro da estrutura organizacional de sua organização. Ainda dentro desse preparo, se começa a documentar o ISMS, ao mesmo tempo em que conscientizamos as pessoas envolvidas sobre a importância do que estamos fazendo.

Com análise de risco, o processo de diagnóstico busca identificar ameaças, brechas e riscos em potenciais aos ativos catalogados no inventário. Com estas ameaças definidas, um plano de tratamento é colocado em ação de acordo com as necessidades.

Dessa forma, com o plano de tratamento em curso, definimos de vez as políticas na fase de implementação, assim como finalizamos a documentação do ISMS. Passamos então para a fase de operação do ISMS, onde buscamos conscientizar os funcionários das novas políticas e começamos o monitoramento e melhoria contínua de todo o processo.

Por fim, precisamos passar por um processo de auditoria interna para garantir a lisura de todos os processos, antes de chamarmos alguma empresa certificada para fazer a auditoria externa, e somente então dar o OK para a certificação de sua empresa, caso todos os requisitos sejam cumpridos, de acordo com a norma ISO 27001.

Considerações Finais da Aula

Nesta aula, tivemos uma visão abrangente e informativa sobre a ISO 27001, destacando seu propósito, estrutura e princípios fundamentais. De maneira clara, este capítulo explica que o propósito da norma em questão é estabelecer um sistema de segurança da informação eficaz para proteger os ativos de informação da organização.

Compreendemos como a norma é capaz de se adaptar à organização, conforme seja necessário, e entendemos a importância da certificação no mercado competitivo. Por isso, fizemos um simples mapa de objetivos e processos necessários para que seja bem-sucedido ao buscar a certificação de uma organização utilizando a norma ISO 27001.

Materiais Complementares



ISO 27001

2005, *International Organization for Standardization*.

Norma comentada ISO 27001.

Disponível em: <https://www.27001.pt/>. Acesso em: 26 jan. 2024.



ISO 27001 – Segurança da Informação

2023, PMG Academy.

Apresenta sucintamente a norma ISO 27001.

Disponível em: <https://www.youtube.com/watch?v=cDwcQchyQ4s>. Acesso em: 26 jan. 2024.



Guia do Framework de Privacidade e Segurança da Informação

2023, Programa de Privacidade e Segurança da Informação (PPSI).

Apresenta o guia do *framework* de privacidade e segurança da informação seguido pelo governo federal.

Disponível em: https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi/guia_framework_psi.pdf. Acesso em: 26 jan. 2024.

Referências

BARRETO, Jeanine dos Santos *et al.* **Fundamentos de segurança da informação**. Porto Alegre: SAGAH, 2018.

MORAES, Alexandre Fernandes de. **Segurança em redes: fundamentos**. São Paulo: Érica, 2010.